

STUDENT	HASSANI Mohammad Salem	INSTRUCTOR	Asen Grozdanov
DATE	January 10, 2026	COURSE	Managing Vulnerabilities

This lab extends the CVE-2025-64446 ATT&CK mapping from Lab 3 by integrating three complementary security frameworks: **MITRE ATT&CK** (adversary behaviour), **NIST Cybersecurity Framework** (governance controls), and **MITRE D3FEND** (defensive countermeasures). Together they form a complete threat-to-defence pipeline.



EXERCISE 1 — CROSS-FRAMEWORK INTEGRATION

1.A · ATT&CK; Technique → NIST CSF Mapping

Each ATT&CK technique in the CVE-2025-64446 kill chain maps to a corresponding NIST CSF function and category, translating adversary behaviour into governance controls:

ATT&CK; Technique	NIST CSF Function	Category ID	Control Rationale
T1190 — Exploit Public-Facing Application	Protect (PR)	PR.AC-1	Identity management and access control for internet-facing web a
T1059.003 — Unix Shell Command Interpreter	Detect (DE)	DE.CM-1	Continuous monitoring of command execution and process creati
T1068 — Exploitation for Privilege Escalation	Protect (PR)	PR.IP-1	Baseline configuration management — harden service account p
T1562.001 — Impair Defenses (Disable Tools)	Respond (RS)	RS.MI-2	Incident response planning — detect and recover from security to

1.B · MITRE D3FEND Countermeasures

D3FEND provides specific defensive techniques mapped directly to ATT&CK. For CVE-2025-64446 the following countermeasures are applicable:

ATT&CK; Technique	D3FEND ID	D3FEND Technique	Implementation
T1190 — Exploit Public App	D3-ANWL	Network Allowlisting	Restrict inbound traffic to WAF management interface to trusted
T1059.003 — Command Interpreter	D3-EHFG	Executable Hardening	Disable unnecessary shell interpreters on the FortiWeb host; en
T1068 — Privilege Escalation	D3-APHS	Application Hardening	Apply principle of least privilege to FortiWeb service accounts; re
T1562.001 — Impair Defenses	D3-DFIC	Decoy File	Deploy canary WAF rules that alert when modified, detecting tar

Synthesis: CVE-2025-64446 → ATT&CK (adversary path: T1190→T1068) → D3FEND (countermeasures: D3-ANWL, D3-EHFG, D3-APHS) → NIST CSF (governance: PR.AC-1, DE.CM-1). Each layer translates the same threat into a progressively more actionable control.

EXERCISE 2 — THREAT-INFORMED ASSESSMENT

2.1 · Semi-Automated Tool: CISA Decider

CISA Decider is a guided ATT&CK technique selection tool that reduces mapping subjectivity by asking structured questions about observed behaviour. Applied to CVE-2025-64446:

Step	Decider Question	Answer	Suggested Technique
1	Is the initial vector a web application vulnerability?	Yes - HTTP path traversal on public WAF	T1190 — Exploit Public-Facing Application
2	Does the attacker execute commands after successful auth bypass?	Yes - admin shell	T1059.003 — Unix Shell
3	Does the attacker gain elevated privileges?	Yes - none to admin	T1068 — Exploitation for Privilege Escalation
4	Does the attacker disable security controls?	Yes - WAF fully compromised	T1562.001 — Disable/Modify Tools

2.2 · Threat Intelligence Summary

Dimension	Intelligence
Exploitation Status	ACTIVE — CISA KEV confirmed (November 2025); GitHub PoC published by WatchTowr Labs
Threat Actors	Ransomware operations targeting edge devices; opportunistic script-kiddie activity due to public PoC
Targeted Sector	Education — Web Application Firewalls are commonly deployed in college and university environments
Attack Timeline	Exploitation observed within days of PoC publication; immediate patching is required

2.3 · Prioritized Recommendation

■ IMMEDIATE ACTION REQUIRED — CVSS 9.8 + CISA KEV + Public PoC

#	Action	Owner	Deadline	Framework Reference
1	Patch FortiWeb to version 8.0.2	Network Team	24 hours	NIST PR.IP-1 / D3-APHS
2	Deploy network allowlisting on WAF	Network Team	48 hours	D3-ANWL / NIST PR.AC-1
3	Deploy Sigma rule for path traversal	SOC SIEM Analyst	72 hours	NIST DE.CM-1 / T1190
4	Ingest WAF logs into SIEM (current gap)	IT Ops	7 days	NIST DE.CM-1
5	Audit ESXi hosts for CVE-2025-22325 patch status	Security Admin	7 days	NIST PR.IP-1

Detection Gap Identified: WAF logs are not currently ingested into the SIEM. Until this gap is closed, the Sigma path traversal rule cannot fire and exploitation attempts will go undetected. Resolving this is action #4 above.

Integrated Assessment Summary

Dimension	Summary
Vulnerability	CVE-2025-64446 — Relative Path Traversal in Fortinet FortiWeb (CVSS 9.8, CISA KEV)
Adversary Path	T1190 (Initial Access) → T1059.003 (Execution) → T1068 (Privilege Escalation) → T1562.001 (Defense Evasion)
NIST Controls	PR.AC-1 (Access Control) · DE.CM-1 (Monitoring) · PR.IP-1 (Baseline Config) · RS.MI-2 (IR Planning)
D3FEND Countermeasures	D3-ANWL (Network Allowlisting) · D3-EHFG (Exec Hardening) · D3-APHS (App Hardening)
Business Risk	Ransomware entry point via perimeter WAF; student data exposure; potential network-wide compromise
Recommendation	Patch FortiWeb to 8.0.2 within 24 hours to eliminate the primary ransomware entry path
Tools Used	MITRE ATT&CK Navigator · MITRE D3FEND · NIST CSF · CISA Decider · CISA KEV